



File No.: EXP202213770

SANCTIONING PROCEDURE RESOLUTION

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter the complainant) filed a complaint with the Spanish Agency for Data Protection on 19/11/2022. The complaint is directed against the UNIVERSITY OF VALLADOLID with NIF Q4718001C (hereinafter, the complained party). The reasons for the complaint are as follows: the complainant states that he participated in a call for positions offered by the complained party, providing extensive documentation with his personal data; however, he became aware that there was a challenge from a participant in the call, who requested documentation submitted to the process by the other candidates, which was provided by the complained party without implementing the necessary security measures to ensure the confidentiality of data for which the complainant does not have a legitimate interest. He points out that the complained party sent him a copy of the request made by the challenger, including the Document Verification Code (C.V.D.), as well as barcodes and QRS that allow full access to the original documents without redaction.

He provides a copy of his application for participation in the call, an excerpt of the complaint filed by the challenger in the call, a complaint raised by the complainant against the complained party, and a copy of the challenger's application in the selection process.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), on 30/12/2022, this complaint was forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on 04/01/2023, as recorded in the acknowledgment of receipt in the file. The DPO, in a letter dated 31/01/2023, responded that after analyzing the incident, he had requested information and that upon reviewing the information provided, a series of risks had been identified.

In its Privacy by Design Guide, the Spanish Agency for Data Protection recommended having privacy design strategies, one of which "hiding" should undoubtedly have been correctly applied.

Instructions had been issued to the governing bodies and corresponding administrative services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/18

Regarding the request from the AEPD to nominally identify the authority or executive responsible for the processing at the time of issuing the technical reports and recommendations, the opinion of the delegate is that a distinction must be made between legal responsibility and management responsibility.

As for the former, the Secretary General has delegated the competencies in directing data protection policy at the University.

However, the tasks of processing the information subject to the complaint have been carried out by the Teaching Staff Service.

THIRD: On 19/02/2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing.

FOURTH: On 10/07/2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringements of Articles 5.1.f) and 32.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR.

FIFTH: After the notification of the initiation agreement on 24/07/2023, the respondent submitted a written statement summarizing the following: that as a consequence of the AEPD's request dated

30/12/2022, after analyzing and verifying the incident that occurred, a report was issued on 28/01/2023 analyzing the existing risks in the anonymization process and proposing a design strategy incorporating measures to avoid situations like the one that occurred. Among these measures, the Proposal for instructions for managing selection processes involving curricular documentation containing personal data was highlighted. On 31/01/2023, the respondent responded to the aforementioned request by providing the reports from the DPD and technical reports and action proposals; as a remedial measure, it was contemplated that the previous document would be made known to the corresponding Service. Working meetings were held, and the document was improved and completed, resulting in the document Instructions for managing selection processes involving curricular documentation containing personal data dated 07/02/2023. The DPD indicated that the use of verification systems for administrative documents based on codes used in Spanish public administrations poses a risk to the privacy of the interested parties, as these systems allow for the download of the original document and that to provide an anonymized copy to those requesting access to the file, it would require the removal of the only element that allows for verifying its authenticity. Thus, access to the submitted documentation would encounter a barrier for those requesting access to public information, as they would not be able to verify the authenticity of the document. To comply with the right to access and obtain a copy of the documents contained in the referenced selection procedure, the documentation requested by the applicant was provided, believing that this communication was covered by the LPACAP and that, nevertheless, in order to mitigate the risk and safeguard the fundamental right to data protection, the respondent has opted to require the masking of the validation number of each document issued electronically. Furthermore, it warns that the risk detected by the respondent regarding the use of documentary verification systems is occurring across all Public Administrations, which is why it requests the AEPD to conduct an Official Audit and issue instructions so that it can be adopted across all Administrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

SIXTH: On 27/09/2023, the opening of a period for the practice of evidence was agreed upon, with the following being established:

To consider reproduced for evidentiary purposes the claim filed by the claimant and its documentation, the documents obtained and generated during the admission phase of the claim, and the report of prior investigative actions that are part of the procedure.

To consider reproduced for evidentiary purposes the allegations to the initiation agreement of the referenced sanctioning procedure, presented by the respondent, and the accompanying documentation.

SEVENTH: On 24/05/2024, a Proposal for Resolution was issued stating that the Directorate of the AEPD declared that the respondent had infringed Articles 5.1.f) and 32.1 of the GDPR, violations classified under Articles 83.5.a) and 83.4.a) of the aforementioned GDPR.

On 06/06/2024, the respondent submitted a written statement of allegations stating, in summary: that, according to the documentation provided, there had been a misapplication of the security measure due to a material error in the obfuscation of the fields, and that a series of measures had been adopted aimed at repairing the damage and improving procedures to prevent similar incidents.

EIGHTH: From the actions taken in the present procedure, the following have been established, PROVEN FACTS

FIRST. On 19/11/2022, a document from the claimant was received by the AEPD in which they state that they applied for a public job offer called through Competition No. XXXX/XX, positions offered by the respondent, providing documentation containing personal data; subsequently, they learned that there was a challenge by one of the participants in the call, requesting the documentation submitted to the process by the other candidates, which was provided by the respondent without implementing the necessary security measures to ensure the confidentiality of the data; they also indicate that the

respondent sent them a copy of the application made by the challenging third party, including the Document Verification Code (C.V.D.), as well as the barcodes and QRS that allow full access to the original documents without redaction.

SECOND. An excerpt from the Resolution of the Rectorate of the University, dated ***DATE.1, is provided, by which Competition No. XXXX/XX is called for the Provision of positions for University Teaching Bodies, in an interim regime and for contracted teaching and research staff under Labor Law, in which the claimant participates.

THIRD. The claimant has submitted their application for participation in Competition No. XXXX/XX for the provision of positions for university teaching bodies.

FOURTH. A document directed by the claimant to the respondent is provided regarding the appeal presented by the challenging participant in the competition against the Provision Proposal made by the Selection Committee of Competition No. XXXX/XX, indicating the possible infringement of data protection legislation and requesting access to the information requested by the challenger, the documentation submitted by them, the documentation that was sent to them, details of the procedure, the method of processing, and the conditions under which the data transfer occurred.

FIFTH. A copy of the complaint filed by the challenging participant against the Provision Proposal made by the Selection Committee of Competition No. XXXX/XX is provided, which prompted the respondent to provide access to the documentation submitted to the competition by the other candidates.

SIXTH. A form containing the personal data of the claimant is provided, sent to the other candidates for the position in the competition, along with the forms with the personal data of the other candidates for the positions in the competition, sent to the claimant with the personal data of their signatories.

SEVENTH. A format for the submission of complaints in selection processes by the respondent is provided, with personal data redacted, maintaining the secure verification codes unredacted and a format for the submission of complaints in selection processes by the respondent that can be accessed through the CVD, with the personal data unredacted.

EIGHTH. The respondent stated in a document dated 24/07/2023:

“(…)

Based on the information obtained, the DPD verified that, although personal data had been concealed in the claimant's file prior to its transfer, this obfuscation did not extend to the secure verification codes and QR codes that allow for the verification of the authenticity of administrative documents on the platforms enabled for this purpose by public administrations.

(…)”

NINTH. In their document dated 31/01/2023, the respondent stated:

“(…)”

Second. - Considering the information provided by the corresponding services of the UVa, the delegate noted the following risks:

(…)”

b) In the file provided to the contestant, most of the personal data has been concealed, although some of it has remained visible. The QR codes or secure verification codes that ensure the authenticity of the documents issued by public administrations have not been removed. A possible human error is observed in the manual redaction of information due to the high volume.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/18

c) There would be a risk of access to personal data due to the obligation of publicity of the secure verification codes provided for in Article 27.3 of Law 39/2015, of October 1, on the Common

Administrative Procedure of Public Administrations. This risk would affect not only the UVa but all public administrations. A series of mitigating measures are proposed for these risks.

(...)

Fourth. - In its Privacy by Design Guide, the Spanish Agency for Data Protection recommends having privacy design strategies, one of which “hiding” should undoubtedly have been correctly applied. The implementation of this strategy requires a “design pattern,” the proposal of which is attached to this document for the consideration of the data controller as “PROPOSAL FOR INSTRUCTIONS FOR THE MANAGEMENT OF SELECTIVE PROCESSES IN WHICH CURRICULAR DOCUMENTATION CONTAINING PERSONAL DATA IS HANDLED.” This action protocol addresses comprehensive management of information from the design of its collection to its eventual delivery in the context of exercising a right of access to public information. Its implementation is recommended as soon as possible. Likewise, it is proposed that the administrative units responsible for the selective processes monitor its deployment to verify its effectiveness.”

(...)

TENTH. It is recorded that a “Proposal for instructions for the management of selective processes in which curricular documentation containing personal data is handled” has been submitted for comprehensive management of the information subject to processing.

ELEVENTH. It is recorded that a Risk Analysis Report has been submitted, considering them adequate and proportionate to the activity, nature, and resources available of the responding party.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/18

II

First obligation breached: infringement of Article 5.1.f) of the GDPR

It should be noted that the responding party carries out the processing of personal data, as it collects, records, and retains personal data, preferably from students, former students, teaching staff, researchers, etc., in accordance with what is stated in Article 4.2 of the GDPR.

The responding party performs this activity in its capacity as the data controller, as it determines the purposes and means related to the processing of personal data, by virtue of Article 4.7 of the GDPR. Additionally, the data controller must also apply the technical and organizational measures that ensure the security of personal data when carrying out the processing. And be able to demonstrate compliance with the GDPR and the LOPDGDD.

The reported facts materialize in the access to personal data by a third party who challenged the call for a selective process in which the responding party also participated, who had requested the documentation submitted by the other candidates for that process, being provided by the responding party without appropriate technical and organizational measures that guaranteed a level of security and confidentiality of data, which would violate the regulations on the protection of personal data.

Article 58 of the GDPR, Powers, establishes in its section 2:

“2. Each supervisory authority shall have all of the following corrective powers:

(...)

d) to order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time;

(...)”

The processing carried out could constitute an infringement of Article 5, Principles relating to processing, of the GDPR, which states that:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).

(...)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/18

The documentation in the file provides clear evidence that the respondent violated Article 5 of the GDPR, principles related to processing, by allowing access to the personal data of the claimant (and the other participants), as it was provided to one of the participants who contested the call in which they participated, infringing the confidentiality and integrity of the data.

In this regard, the aforementioned Article 5.1(f) of the GDPR states that personal data shall be processed in a manner that ensures its security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures.

Also, Recital 39 of the GDPR, in clear reference to the principle set out in Article 5.1(f) of the GDPR, provides that: “Personal data must be processed in a manner that ensures appropriate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used for processing.”

The loss of confidentiality poses a risk that may lead to material or immaterial damages for individuals (Recital 85 of the GDPR). In this sense, Recital 75 of the GDPR establishes that: “The risks to the rights and freedoms of individuals, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; ...”

Therefore, unauthorized access to personal data means that it may be used for unknown, even fraudulent purposes, leading to a total and absolute loss of control over it. It should also be noted that most of the leaked personal data are data that cannot be modified or changed for others (name, surname, ID number, address, etc.).

In this same sense, Article 28 of the LOPDGDD, regarding the obligations of the data controller within the framework of Articles 24 and 25 of the GDPR to ensure and demonstrate that the processing is compliant with the GDPR concerning various risks, states that,

“(...

2. In adopting the measures referred to in the previous paragraph, data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

unauthorized reversal of pseudonymization or any other significant economic, moral, or social harm to those affected. ...”.

And the Judgment of the Constitutional Court (STC) 292/2000 in the seventh legal foundation states: “... it follows that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that enables the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may collect, and that also allows the individual to know who holds that personal data and for what purpose, being able to oppose that possession or use. These powers of disposition and control over personal data, which are part of the content of the fundamental right to data protection, are legally concretized in the ability to consent to the collection, obtaining, and access to personal data, its subsequent storage and processing, as well as its possible use or uses, by a third party, whether the State or a private individual.”

It should be noted that the very party being claimed against, in a document dated 31/01/2023, stated that:

“(…)

- a) The file access system does not allow for traceability of access to information and acknowledgment of receipt.
- b) In the file provided to the claimant, most of the personal data has been concealed, although some of it has remained visible. The QR codes or secure verification codes that ensure the authenticity of the documents issued by public administrations have not been removed. A possible human error is observed in manually censoring the information due to the high volume.
- c) There would be a risk of access to personal data due to the obligation of publicity of the secure verification codes provided for in Article 27.3 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations. This risk would affect not only the UVa but all public administrations.

(…)” (The underlining corresponds to the AEPD).

And also in a document dated 24/07/2023, it stated that:

“Second. - Based on the information obtained, the DPD verified that, although personal data had been concealed in the claimant's file prior to its transfer, this obfuscation had not extended to the secure verification and QR codes that allow for the verification of the authenticity of administrative documents on the platforms enabled for this purpose by public administrations.

Once the existence of the material error due to the lack of concealment of the secure verification and QR codes was verified, the DPD issued report No. REF. UVA/01/2023 (2), dated January 28, 2023, in which the existing risks in the anonymization process were analyzed and a privacy design strategy was proposed that incorporated a series of remedial measures to prevent the situation from recurring in the future.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

On the other hand, the claimant provides the complaint filed by the third party participating in the Contest against the Provision Proposal, an instrument through which the party being claimed against provided the documentation submitted for the contest by the other candidates, including that of the claimant, where their personal data appears.

It also provides the form containing the personal data of the claimant, which was sent uncensored to the other candidates for the position in the contest, and the forms with the personal data of the other candidates for the positions in the contest, sent to the claimant with the personal data of their signatories.

Therefore, this conduct constitutes a violation of the principle of integrity and confidentiality of data in

accordance with the provisions of Article 5.1.f) of the GDPR, an infringement classified in Article 83.5 of the GDPR.

III

Classification of the infringement of Article 5.1.f) of the GDPR

Article 83.5 a) of the GDPR considers that the infringement of “the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9” is subject to sanction. For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

Also, the LOPDGDD, for the purposes of prescription, in its Article 72 indicates:

“Very serious infringements:

1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and will prescribe in three years, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)”

IV

Second obligation breached: infringement of Article 32.1 of the GDPR

The party being claimed against is also attributed with the infringement of Article 32 of the GDPR

“Security of processing,” which establishes that:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement technical and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/18

appropriate organizational measures to ensure a level of security adequate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, particularly as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law.”

The GDPR defines personal data security breaches as “all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

The documentation in the file evidences the violation of Article 32.1 of the GDPR, as a consequence of the lack of appropriate technical and organizational measures that ensure a level of security adequate to the risk of processing.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures that are applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made taking into account: the pseudonymization and the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/18

encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), assessment, and evaluation of the effectiveness of the measures.

In any case, when assessing the adequacy of the security level to the risk, particular consideration will be given to the risks presented by data processing, as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial harm.”

In the present case, it is evident that the security measures that the responding party had implemented in relation to the data they processed were not appropriate or adequate to ensure the security of personal data at the time the processing occurred.

As Recital 39 also points out:

“...Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used in the processing.”

In the present case, as stated in the proven facts, the responding party sent a copy of the request made by one of the participants who challenged the proposal for provision made by the Selection Commission of the Contest, including the Document Verification Code (C.V.D.), as well as barcodes and QRs that allowed full access to the original documents without redaction. Additionally, some data remained visible and unhidden.

The responding party has confirmed the incident caused and also stated that “In its Privacy by Design Guide, the Spanish Agency for Data Protection recommends having privacy design strategies, one of which ‘hiding’ should undoubtedly have been applied correctly.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

It should be noted that security measures are key to guaranteeing the fundamental right to data protection, as it is not possible to ensure this right if confidentiality, integrity, and availability of personal data cannot be guaranteed. To ensure these security factors, both technical and organizational measures that are adequate are necessary.

In the report dated 05/01/2023 submitted by the DPD, it was stated that: "On August 17, 2022, the challenging participant submitted a written request for 'an electronic copy of all documentation in the file related to the positions PAYUD K070K06/RP06017 and PAYUD K070K06/RP06018 of said competition; specifically, the documentation submitted by the other candidates, the detailed scoring of all candidates according to the specific criteria of the competition, and the minutes of the meetings of the commission, for the purpose of being able to formulate the claims that he deems pertinent.' This request, in accordance with articles 13.d) and 53.1.a) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, was addressed, and the following day, via email which attached an official letter from the Head of the Labor PDI Access Section of the Teaching Staff Management Service, the censored documentation submitted by the other candidates for said positions was made available to him, as he was a candidate in the selection process, having a personal, direct, and legitimate interest in knowing the content of the files of the administrative procedure.

On August 30, 2022, the challenging participant submitted a written complaint against the proposal for provision of the Selection Commission, in accordance with the provisions of base 7.5 of the corresponding call, for evaluation by the complaints commission.

Subsequently, this complaint was communicated to the other participants in the procedure, for the defense of their rights, and in response, the complainant submitted a written statement indicating that the transfer to a third party of documentation containing his personal data could violate the legislation on data protection, and therefore requested access to his application and to the documentation that was sent to him and that contained information submitted to the file by the complaining party, details of the procedure, method of processing, and conditions under which the data transfer occurred, as well as the transfer of the complaint to the DPD.

Furthermore, it is noted in the aforementioned report that: The censorship process carried out on the documents sent to the interested parties (number of censored pages 1,067) is performed manually by the service staff as quickly as possible to address the requests, since the interested parties need it to defend their rights in the claims they submit. The interested parties have a period of 10 days to submit such claims."

In this regard, related to the censorship process, it was recommended that "It is the administration's obligation to adjust the available resources to the needs of the service. And it is evident that risk management requires having sufficient and trained personnel for the partial anonymization of documents within the framework of the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

management of competitions in which, as is the case, the decision essentially relies on a process of scoring among applications that present a significant volume of merits."

To conclude, regarding the omission of transferring the claimant's written submission to the Data Protection Delegate and the Privacy Officer, it was stated that "it has been overlooked as it was incorporated in the allegations procedure requested from the interested party and which was included in the appropriate complaint file before the Complaints Commission without this request being noted by either the Service staff or the members of said Commission. An omission that was never intended to evade said request."

Furthermore, in the document dated 31/01/2023, the responding party states that "in the file provided to the contestant, most of the personal data has been concealed, although some of it has remained visible. The QR codes or secure verification codes that ensure the authenticity of the documents

issued by public administrations have not been removed. A possible human error is observed when manually censoring the information due to the high volume.

It should be noted that security measures are key to guaranteeing the fundamental right to data protection, as it is not possible to ensure this right if confidentiality, integrity, and availability of personal data cannot be guaranteed. To ensure these security factors, both technical and organizational measures that are adequate are necessary.

The adequacy of the level of security to the risk must be evaluated by the controller and reconsidered periodically based on the results obtained, taking into account - among other factors - the risks that may arise from the unauthorized communication of such data.

The technical and organizational security measures that must be applied are those pertinent to respond to the existing risk, assessing, among other factors, the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity risks to the rights and freedoms of the data subjects.

One of the requirements established by the GDPR for controllers and processors who carry out processing activities with personal data is the need to conduct a risk analysis of information security in order to establish security and control measures aimed at complying with the principles of protection by design and by default that guarantee the rights and freedoms of individuals.

The responsibility of the claimant is determined by the lack of suitable and necessary technical and organizational measures evidenced, as they are responsible for making decisions aimed at effectively implementing appropriate measures to ensure an adequate level of security in relation to the risk to ensure the confidentiality of the data, restoring its availability, and preventing access to it in the event of a physical or technical incident. In this regard, the measures were not appropriate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/18

In accordance with the above, it is estimated that the respondent would be presumably responsible for the infringement of the GDPR: the violation of Article 32.1, an infringement classified in its Article 83.4.a) of the GDPR.

V

Classification of the infringement of Article 32.1 of the GDPR

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.

(...)”

For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

And in its Article 73, for the purposes of prescription, qualifies as “Infringements considered serious”:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations for infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)”

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

(...)”

VI

Applicable regime for committed infringements

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes: “Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/18

Also, the LOPDGDD in its Article 77, Regime applicable to certain categories of data controllers or processors, establishes the following:

“1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

(...)

i) Public Universities.

(...)

“2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed, with the exception of that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which they hierarchically depend, where applicable, and to the affected parties who had the status of interested parties, where applicable.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is accredited, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions concerning the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it shall publish on its website, with due separation, the resolutions referred to the entities in paragraph 1 of this article, with explicit indication of the identity of the controller or processor who has committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions shall be governed by its specific regulations.”

In the case examined, the present sanctioning procedure has its cause, as stated in the facts, from the violation of the regulations on personal data protection, both of the principle of confidentiality of the data and the technical and organizational measures implemented.

In accordance with the evidence available, such conduct constitutes, on the part of the accused party, the infringement of the provisions of Articles 5.1.f) and 32.1 of the GDPR.

It should be noted that the GDPR, without prejudice to what is established in its Article 83, contemplates in its Article 77 the possibility of declaring the infringement and establishing the measures that should be taken to correct the processing of personal data that do not comply with its provisions, when the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law.

Additionally, Article 58 of the GDPR, in its paragraph 2 d), states that each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”.

However, it should be emphasized that the accused party has stated that, once the incident was analyzed, it had adopted measures to prevent incidents like the one that led to this procedure from occurring again, attaching the document “PROPOSAL FOR INSTRUCTIONS FOR THE MANAGEMENT OF SELECTIVE PROCESSES IN WHICH CURRICULAR DOCUMENTATION CONTAINING PERSONAL DATA IS PROCESSED.”

Thus, in the written response to the Agency's request, it stated that:

“This action protocol addresses a comprehensive management of information from the design of its collection to its eventual delivery within the framework of exercising a right of access to public information. Its implementation is recommended as soon as possible. Likewise, it is proposed that the administrative units responsible for the selective processes monitor its deployment to verify its effectiveness.

- The “PROPOSAL FOR INSTRUCTIONS FOR THE MANAGEMENT OF SELECTIVE PROCESSES IN WHICH CURRICULAR DOCUMENTATION CONTAINING PERSONAL DATA IS PROCESSED” has been submitted by the accused party to the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/18

Fifth. - Various instructions have been issued to the relevant governing bodies and administrative services, as can be seen in the following annexes:

- Official letter regarding the adoption of instructions for data concealment. The instructions on anonymization in selection processes are communicated to all services responsible for their management and to the body responsible for resolving requests for access to public information.
- Official letter from the Information Security Committee. It is tasked with verifying, monitoring, and remedying the security incident affecting the confidentiality of the use of secure verification codes.
- Official letter to the responsible parties of the electronic headquarters. Developers are requested to understand the legal grounds used for the specification of requirements for the Electronic Headquarters software and to take into account the recommendations of the data protection delegate for the future development of the application.

Finally, regarding what was stated by the responding party in their allegations to the initiation Agreement: “The detected risk arising from the use of documentary verification systems by public administrations, which, as has been verified, the University of Valladolid had not taken into account, may be occurring in a generalized manner across the entire Administration, which is why we would like to take this opportunity to request the Spanish Agency for Data Protection to initiate an ex officio audit to verify what the common administrative practice is in these situations and to issue precise instructions that can be adopted by all public administrations,” the responding party is informed that this agency has duly noted the remarks and has forwarded them to the Division of Technological Innovation for analysis and action as deemed appropriate.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the UNIVERSITY OF VALLADOLID, with NIF Q4718001C, has infringed the provisions of Article 5.1.f) of the GDPR and Article 32.1 of the GDPR, violations classified under Articles 83.5.a) and 83.4.a) of the GDPR.

SECOND: TO NOTIFY this resolution to the UNIVERSITY OF VALLADOLID.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/18